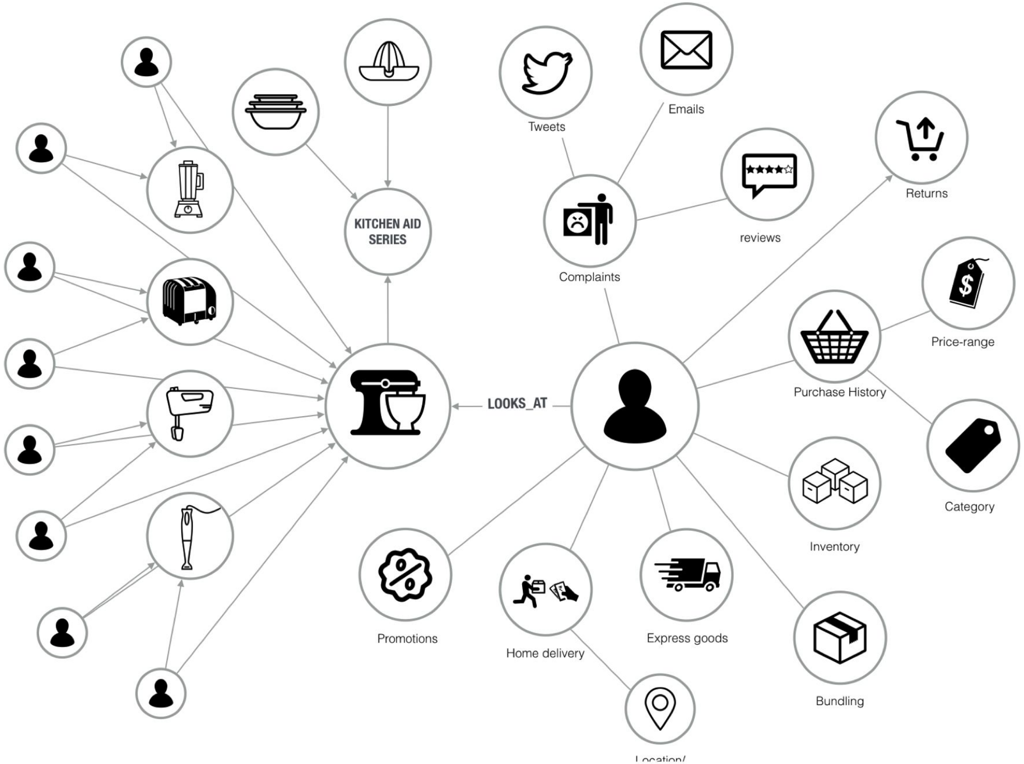
(In) Security in graph databases

Analysis and data leaks

Dr. Alfonso Muñoz - @mindcrypt
Senior Cybersecurity Expert & Research Lead

Miguel Hernández - @MiguelHzBz
Data analyst & Security Researcher



Agenda

- Why this research? Why Graph databases?
- Summary of findings (Neo4j & Oriendtb)
- Attacks in Neo4j & OrientDB
- Internet exposure
- Conclusions

Why this research? Why Graph Databases? Analytics?

Why Facebook and the NSA love graph databases

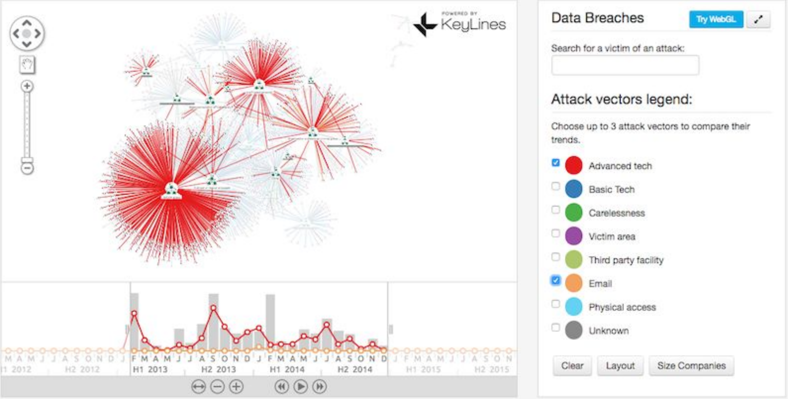
searchdatacenter.techtarget.com/feature/Why-Facebook-and-the-NSA-love-graph-databases

ars TECHNICA UK

GCHQ open-sources surveillance graph database software on GitHub

Released under Apache licence, Gaffer may look for the "boss" of a network.

ANDRII DEGELER - DEC 15, 2015 11:05 AM UTC



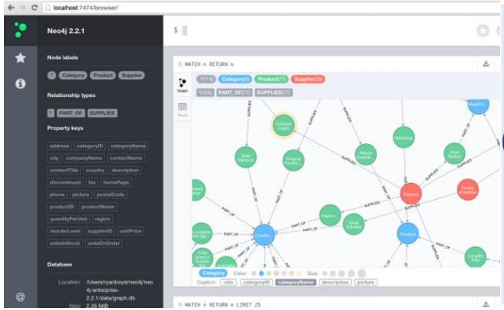
23 systems in ranking, February 2017

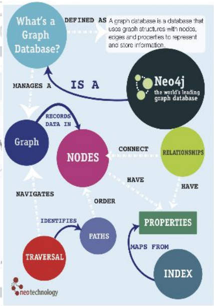
Rank Feb 2017	Rank Jan 2017	Rank Feb 2016	DBMS	Database Model	Score Feb 2017	Score Jan 2017	Score Feb 2016
1.	1.	1.	Neo4j	Graph DBMS	36.27	+0.00	+3.98
2.	2.	2.	OrientDB	Multi-model	5.87	+0.06	-0.55
3.	3.	3.	Titan	Graph DBMS	5.08	-0.42	-0.27
4.	4.	↑ 5.	ArangoDB	Multi-model	2.48	+0.07	+1.04
5.	5.	↓ 4.	Virtuoso	Multi-model	2.14	-0.23	-0.85
6.	6.	6.	Giraph	Graph DBMS	1.03	-0.01	+0.05
7.	↑ 8.	7.	AllegroGraph	Multi-model	0.48	+0.02	-0.18
8.	↓ 7.	8.	Stardog	Multi-model	0.46	-0.07	-0.08
9.	9.	↑ 17.	GraphDB	Multi-model	0.35	+0.05	+0.26
10.	10.	↓ 9.	Sqrrl	Multi-model	0.29	+0.03	-0.05
11.	11.	↓ 10.	InfiniteGraph	Graph DBMS	0.22	+0.04	-0.09
12.	↑ 13.		Dgraph	Graph DBMS	0.19	+0.06	
13.	↑ 15.	↑ 18.	Blazegraph	Multi-model	0.14	+0.06	+0.07
14.	14.	14.	FlockDB	Graph DBMS	0.12	+0.02	-0.02
15.	↓ 12.	15.	InfoGrid	Graph DBMS	0.11	-0.05	-0.03
16.	↑ 17.	↓ 13.	HyperGraphDB	Graph DBMS	0.09	+0.03	-0.08
17.	↓ 16.	↓ 12.	GlobalsDB	Multi-model	0.06	+0.00	-0.12
18.	18.	↑ 19.	GraphBase	Graph DBMS	0.03	-0.00	-0.01
19.	19.	↓ 11.	Sparksee	Graph DBMS	0.02	-0.01	-0.18
20.	↑ 21.		AgensGraph	Multi-model	0.00	±0.00	
20.	↑ 21.	20.	Amisa Server	Multi-model	0.00	±0.00	±0.00
20.			GRAKN.AI	Graph DBMS	0.00		
20.	20.	↓ 16.	VelocityGraph	Graph DBMS	0.00	-0.00	-0.12

By 2020, sophisticated criminals will be able to beat 90% of the organizations who have deployed advanced analytic systems.

The Fast Evolving State of Security Analytics 2016 - **Gartner**

Adversarial Machine Learning & GAN (Generative Adversarial Networks) neo4j



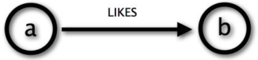


Neo4j is a graph database management system developed by Neo Technology, Inc. in java. Described by its developers as an ACID-compliant transactional database with native graph storage and processing.

In **Neo4j**, everything is stored in the form of either an edge, a node, or an attribute.

Cypher (Graph Query Language)

Cypher using relationship 'likes'



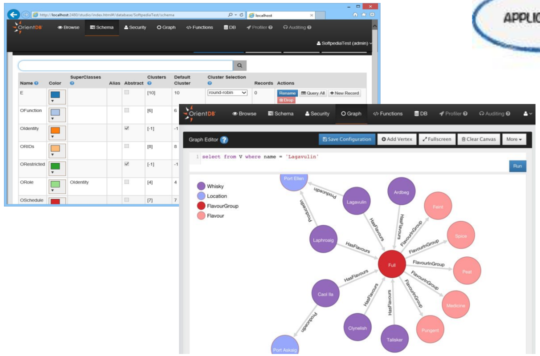
Cypher

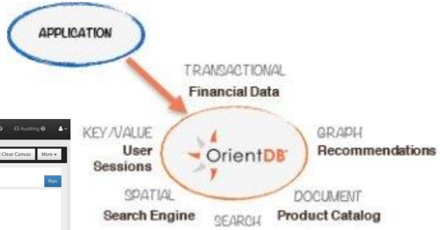
(a) -[:LIKES]-> (b)

OrientDB®

Why OrientDB? | Products | Learn | Services | Company | Download

OrientDB - The World's First Distributed Multi-Model NoSQL Database with a Graph Database Engine



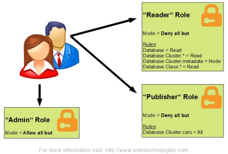


Operations

Looking for Incremental Backups? We've got that covered. What's more, with OrientDB's latest 2.2 version, the new OrientDB Studio adds a new peer-to-peer architecture and new modules. We've also officially released Teleporter: a new tool to sync with relational databases and simplify migrations to OrientDB. OrientDB 2.2 also introduces the Neo4j to OrientDB Importer, allowing you to import your Neo4j graph to OrientDB in a few simple steps.

Manage virtually every aspect of your database through OrientDB Studio.

OrientDB – Security



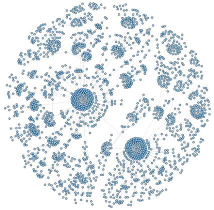
Summary of findings (Neo4j & Oriendtb)

- Design Errors
  - Best password hashing option (**Neo4j**).
  - Possibility to access root account directly (**OrientDB**).
  - Possibility to replace root credentials without response of server (**Neo4j**).
  - Security measures based on licenses (pay for more security) (**Neo4j**).

- Configuration Errors
  - Exposed database to Internet by default (**OrientDB**).
  - Create default users and databases (**OrientDB**).

- Security Errors
  - User management is not provided (**Neo4j < 3.1 version**).
  - Send OPTION requests with a database with authentication (**Neo4j**).
  - Vulnerable versions are currently used (**Neo4j & OrientDB**).
  - HTTP protocol (**Neo4j & OrientDB**).

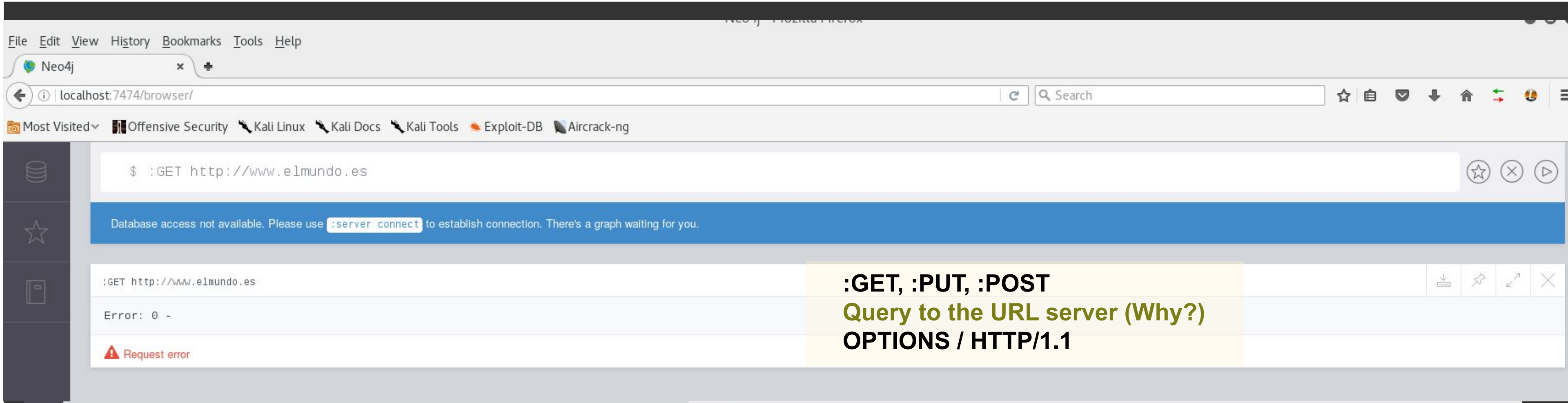
Security considerations in Neo4j



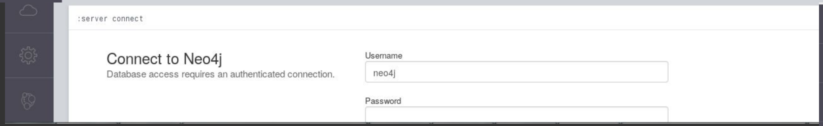
- Vulnerability for < 1.9.x: CVE-2013-7259 execute arbitrary code (DefCon 21)
- User Management
  - Only one user: neo4j in all versions < 3.1
  - User/password by default: neo4j/neo4j
  - Improper password management
    - Bad password policy (from 1 character and no without characters restriction)
    - Better options for password store (now sha256+salt).
    - Insuffer anti-automatitation password attacks (delay 5 seconds each 3 password tries)
      - It is possible password brute-force attack from different IPs (Proxies…)
      - Attack without response (change password) - **http://ip:7474/user/neo4j/password**

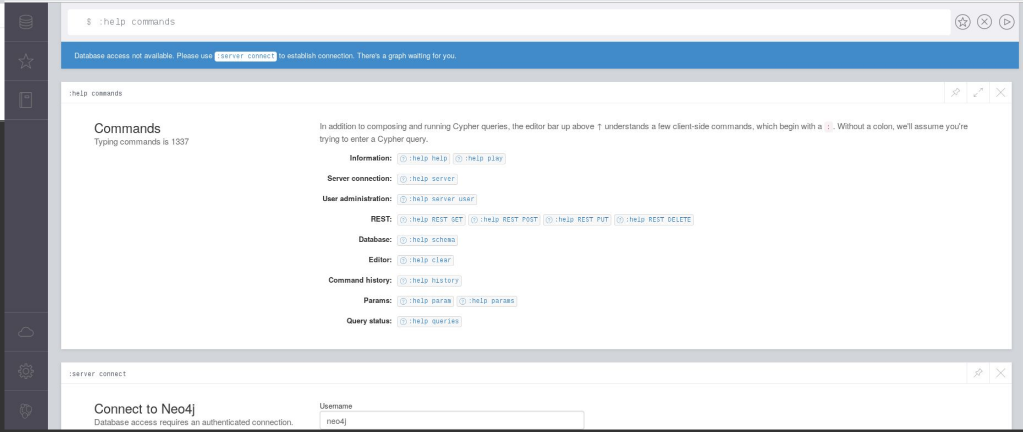
- Database fingerprinting: Neo4j is 3.x or lower (fixed paths)
- Community & Enterprise license: Logs (query and security logs) only in Enterprise Edition.
- ¿Database exposure?
  - Authentication enabled by default: dbms.security.auth_enabled=true
  - Not exposed to Internet by default: server.webserver.address=0.0.0.0
- Send “anonymous” queries to other sites…

Notes: Attacks from Neo4j "without credentials"

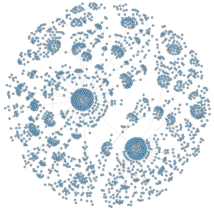


:GET, :PUT, :POST
Query to the URL server (Why?)
OPTIONS / HTTP/1.1





Notes: Attacks in Neo4j “with credentials”

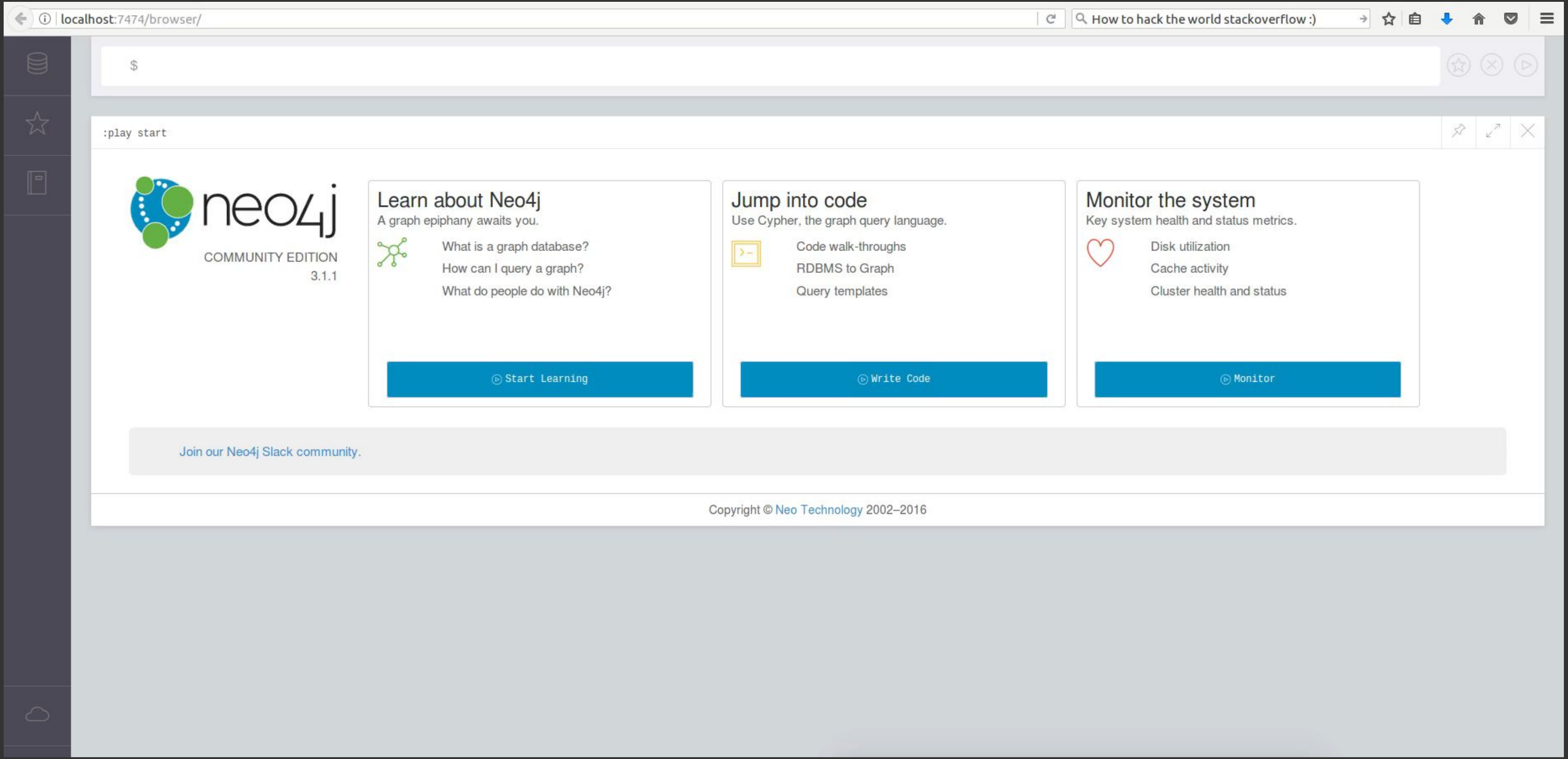


- **If an attacker has the password for the Neo4j user (database empty, password by default, password guessing or software/apps with improper parameter validation connecting with Neo4j db)**

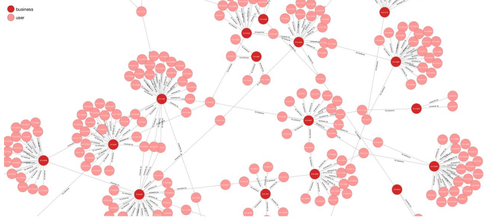
- Database “DUMP”
  - MATCH (N)-[R]-(M) RETURN N,R,M
- Database “DROP”, INSERT o MODIFY (C&C, ilegal material, cover channels, …)
  - MATCH (N)-[R]-(M) DELETE N,R,M (LIMIT 10000)
- RAM DoS
  - FOREACH (x in range(1,10000000000000) | CREATE (:Person {name:"name"+x, age: x%100}));
- Disk DoS
  - USING PERIODIC COMMIT 1000 LOAD CSV FROM {url} CREATE (a:person{name:row[0]);
- **New way of Ransomware**
  - 1. – Compute “functions” on the Graph Databases (replace + homophonic Cipher)
  - 2. – Where are the links among nodes?
  - 3. – if combine 1+2+…

VIEW DEMO

Ransomware attacks – Neo4j



Security considerations in OrientDB



- Variety of versions: We analyze the last versions 2.2.x, in 2016/2017
- Two licenses, community and enterprise (the same security approach)
- Starting the server (1 OrientDB server -> N databases)
  - OrientDB server have always the root user / remote connection.
  - OrientDB stores password using PBKDF2 algorithm
  - 3 default users per each database (admin/admin,writer/writer, reader/reader)
  - A specific database is "created", the name is GratefulDeadConcerts.
- Bad documentation (User's Manual) – Mistakes about security
  - OrientDB exposed to Internet by default, and "that is NOT recommended in the documentation"
- Security problems
  - You can list ALL databases without authentication (http://<ip>:2480/listDatabases)
  - Fingerprinting of the version database (http://<ip>:2480/listDatabases)
  - Default credentials in each database.
  - No countermeasures against brute-force login attacks.
  - Brute-force attacks to root account (remote)
  - Fast download database: http://ip:2480/database/export

While OrientDB can function as a regular Web Server, it is not recommended that you expose it directly to the internet or to public networks. Instead, always hide the OrientDB server within a private network.

GitHub

https://github.com/grafscan/GraFSCaN

***GraFScaN:* First pentesting tool for auditing graph databases. Neo4j, OrientDB, Arango, AllegroGraph, Virtuoso…**

GraFScaN Help:

```
-------------------------------------------
|          GraFScaN                       |
|                                         |
| Authors: Miguel Hernández (@MiguelHzBz)|
|          Alfonso Muñoz (@mindcrypt)    |
| Version: v1.0                           |
|                                         |
| Last update: April 28, 2017             |
-------------------------------------------

A pentesting tool for graph databases

usage: GraFScan.py [-h] [-neo4j] [-orient] [-arango] [-virtuoso] [-allegro]
               [-all] [-ip IP] [-n NET] [-i FILEINPUT] [-o OUTPUT] [-B]
               [-dict DICT] [-proxies PROXIES] [-nl] [-tor] [-DoS]

GraFScaN analyses the input to search Neo4j, OrientDB, ArangoDB, AllegroGraph and VirtuosoDB graph database.

optional arguments:
  -h, --help            show this help message and exit
  -neo4j                Discover and analyze Neo4j Graph database
  -orient               Discover and analyze Orient Graph Database
  -arango               Discover and analyze Arango Graph Database
  -virtuoso             Discover and analyze virtuoso Graph Database
  -allegro              Discover and analyze allegro Graph Database
  -all                  Discover and analyze All Graph Database
  -ip IP                Input one ip to analyse.
  -n NET, --network NET Input one network to analyse.
  -i FILEINPUT          Input one file with one ip each line to analyse.
  -o OUTPUT             Output file
  -B, --bruteforce      Option to use brute force with authentication Neo4j.
  -dict DICT            Dictionary file, one password per line
  -proxies PROXIES      Proxies file, format: <ip>:<port>
  -nl, --no-limit       Option to dump all database of Neo4j without auth.
  -tor                  Option to use proxy TOR to scan de input data, need
                        install and run before executed.
  -DoS                  Option to use DoS without authentication Neo4j.
```

Output:

Neo4j with auth:

- ip: Ip analyzed.
- authentication: True.
- version: < 3.X or > 3.X.
- change_password: boolean if the bruteforce was succesfull or not, and add old_password if was true. Only if you use brute force option.

Neo4j without auth:

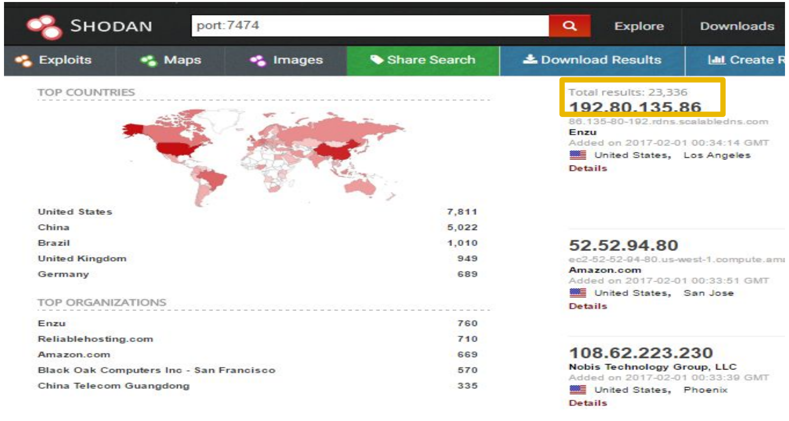
- Info: Json with the return of query in cypher Match (n)-[r]-(m) Return n,r,m.
- license: Two values, version and license, communtiy or enterprise.
- NumNodes: Number of index to the nodes.
- ip: Ip analyzed.
- NumProperties: Number of index to the properties.
- NumRelationships: Number of index to the edges.
- labels: Array with all labels of nodes in the graph database.
- props: Array with all the key of all properties in the graph database.
- types: Array with all labels of edges in the graph database.
- cluster: Boolean to know if this instance is part of cluster, if the value is true, appear if this instance was slave or master.
- version: Version of Neo4j instance.

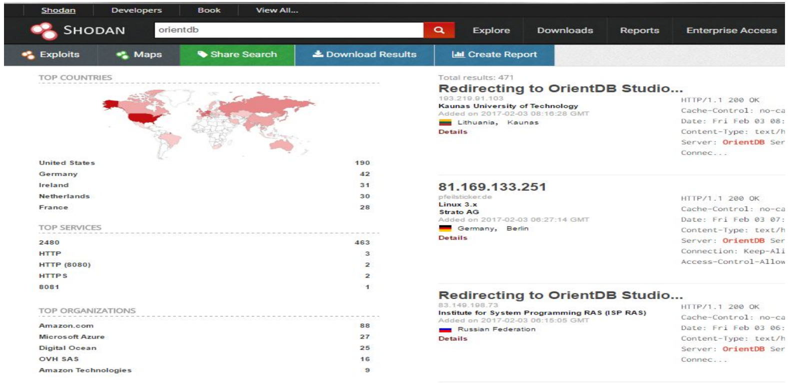
OrientDB:

- databases: Array with all names of databases in OrientDB Server.
- version_OrientDB: Version of OrientDB Server.
- server_pass: Password of root user.
- serer_info: Json object with all information of server: connections, globalproperties, storadges and properties. Only if you use brute force option.

The tool tries to export all databases in the OrientDB Server, it creates a folder with the IP as name and put into the compress databases. Only use default auth to send the request.

Internet and Neo4j/OrientDB
Shodan, Zmap, Masscan…

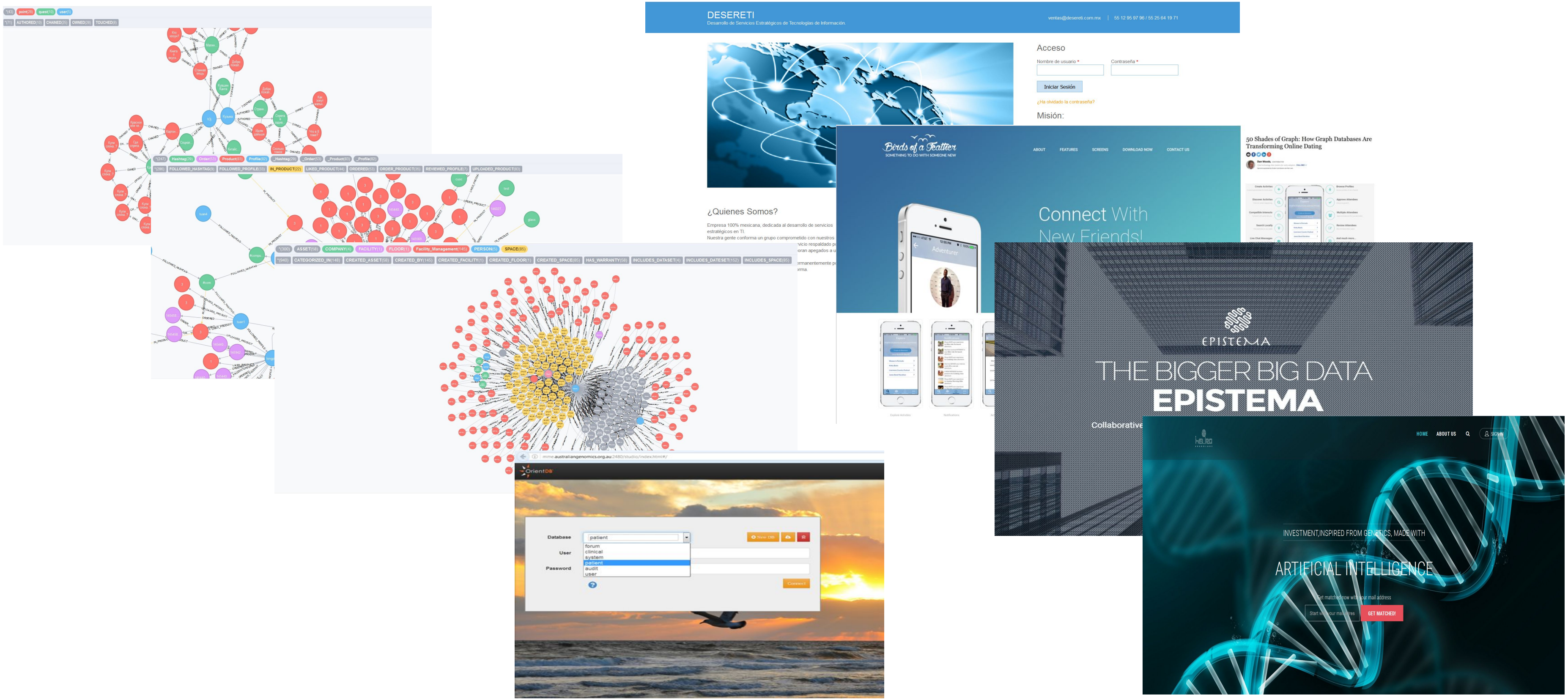




Neo4j Databases				
Potential Neo4j Databases	33772			
Databases	~1300			
With authentication	~1000			
Empty Databases	28			
Without authentication	1.9	2.X	3.0	3.1
	17	251	30	0

OrientDB Databases				
Potential OrientDB Servers	3792			
Servers	214			
Databases	553			
Versions	1.x	2.0	2.1	2.2
	16	30	64	104

Examples


DESERETI
Desarrollo de Servicios Estratégicos de Tecnologías de Información.
Acceso
Iniciar Sesión
Misión:
¿Quienes Somos?
Birds of a Feather
Connect With
New Friends!
50 Shades of Graph: How Graph Databases Are Transforming Online Dating
EPISTEMA
THE BIGGER BIG DATA
EPISTEMA
Collaborative
OrientDB
Database
User
Password
patient
forum
clinical
system
patient
audit
user
INVESTMENT,INSPIRED FROM GENETICS, MADE WITH
ARTIFICIAL INTELLIGENCE
GET MATCHED!

Conclusion – Security Graph Databases

- What do you think? - (In) Security Graph Databases
- 1st Graph Databases hacking tool (PoC): **`https://github.com/grafscan/GraFSCaN`**
- +600 exposed graph databases: public organisms, companies, "security controls", …
- Security design issues: default configuration, brute-force login attacks, "password policies", password storage, "queries to third-parties", DoS and Ransomware attacks…
- Basics: Configuration?, Configuration?, ….

`https://neo4j.com/docs/operations-manual/current/security/checklist`

/orientdb-community-2.2.15/config/security.json

/orientdb-community-2.2.15/config/orientdb-server-config.xml

Why Cybersecurity Should Be The Biggest Concern Of 2017

POST WRITTEN BY

Cesar Cerrudo

Cesar Cerrudo is a professional hacker and the CTO of IOActive Labs, where he works on cutting-edge cybersecurity research.

I've been a professional hacker for more than 15 years. I find cybersecurity problems in technology in order to make that technology more secure. But after doing this for many years, I'm frustrated. I see the same problems over and over again. We are not getting better. And while we depend more and more on technology, technology is becoming more and more insecure.

Questions & doubts?

(In) Security in graph databases – Analysis and data leaks

Dr. Alfonso Muñoz
@mindcrypt @criptored
alfonso@criptored.com
alfonso.munoz@i4s.com
LinkedIn: http://goo.gl/2UbFSf

Miguel Hernández Boza
@miguelhzbz @i4ssecurity
miguelhernandez2907@gmail.com
Miguel.hernandez@i4s.com
LinkedIn: http://goo.gl/bkhJHw

Thanks!!!